Informe Clase 3 · Codificación Segura

Fase 1: Teoría | Fase 2: Investigación en Código | Fase 3: Evidencia y Mitigación NIST

OVA: Herramienta de Seguridad en Redes desde Cero	**Fecha:** 3 de noviembre de 2026
Equipo: CyberDefender	**Herramienta:** NetTrap-IPS (Defensa Activa)
Institución: UNIPAZ	**Entrega:** Clase 3 de 5 (Anexo a Clase 1 y 2)

Integrantes del Equipo CyberDefender:

#	Cédula	Nombre Completo	Rol Técnico
1	1096802414	Michel Daniela Bayona Diaz	Responsable de Seguridad & Normas
2	1014189353	Margit Dayanna Barrera Gutiérrez	Desarrolladora (Backend & Mitigación)
3	1092528951	Said Alexander Pacheco Moncada	Líder Técnico & Documentador

Regla Normativa de Clase 3: Todo control de seguridad implementado debe respaldarse con **(1) base teórica comprendida**, **(2) investigación registrada en el código fuente con cita de cláusulas de ISO/IEC 27033, NIST SP 800-218 (SSDF) u OWASP ASVS**, y **(3) evidencia verificable**. Sin estos componentes, el control no cuenta para evaluación.

1. Fase 1 · Fundamentos Teóricos de Codificación Segura

Para el desarrollo de la herramienta defensiva NetTrap-IPS se estudiaron e integraron cuatro pilares de ingeniería segura derivados de **OWASP ASVS v5.0** y **NIST SP 800-218 (SSDF)**:

Pilar de Seguridad	Principio Operativo y Justificación Técnica	Norma / Control
Validación de Entradas	**Toda entrada es hostil:** Se prohíbe delegar la seguridad en el cliente. Se aplica validación positiva (lista blanca estricta) mediante tipos canónicos y analizadores semánticos (ipaddress) antes de cualquier operación en el sistema operativo.	OWASP ASVS V5.1.1 / V5.5 NIST SSDF PW.7
Manejo de Errores y Logging	**No alimentar al atacante:** Las excepciones internas nunca exponen stack traces, rutas del sistema de archivos ni versiones de librerías. El usuario recibe un mensaje genérico mientras que el detalle forense se escribe en logs locales inmutables (append-only) sin registrar credenciales ni secretos.	OWASP ASVS V7.1.1 / V7.4.1 ISO 27033-1 Cl. 10.3
Criptografía y Sesiones	**Criptografía estándar:** En tránsito se exige TLS 1.2+ deshabilitando suites inseguras (RC4, 3DES). En reposo, el almacenamiento de claves administrativas utiliza funciones lentas adaptativas (Argon2id / bcrypt con salt automático). Sesiones efímeras con tokens criptográficos de 32 bytes.	OWASP ASVS V6.2 / V9.1 NIST SSDF PW.9.1
Análisis Estático (SAST)	**Auditoría automatizada de código:** Detección temprana de llamadas inseguras a subprocesos, sockets abiertos indiscriminadamente y credenciales embebidas (hardcoded secrets) antes de la fase de despliegue.	NIST SSDF PW.7.1 NIST SSDF PS.1.1

2. Fase 2 · Investigación Técnica: Aplicación de Controles en NetTrap-IPS

Se auditó directamente el código fuente desarrollado en src/backend/ para contrastar cada control implementado frente a su especificación normativa y verificar su efectividad defensiva:

#	Control Implementado	Norma / Cláusula	Archivo / Línea	Hallazgo Detallado de la Investigación
1	**Validación y sanitización de direcciones IP**	OWASP ASVS v5.0 V5.1.1 ISO 27033-1 Cl. 10.3	honeypot.py: L40-54 mitigator.py: L41-48	Se investigó la función validate_ip(raw_ip) y _safe_ip(ip). Utiliza la librería estándar ipaddress.ip_address() como lista blanca estricta. Si una entrada contiene caracteres de inyección de comandos shell (; & | ` $) o no cumple la sintaxis IPv4/IPv6 canónica, se descarta y jamás llega a subprocess ni a netsh. Cumple positivamente el control V5.1.1.
2	**Manejo seguro de excepciones y log de auditoría**	OWASP ASVS v5.0 V7.4.1 NIST SSDF PW.9.1	correlator.py: L114-121 mitigator.py: L245-260	Se verificó la función _audit() y _audit_block(). Escriben eventos en formato JSONL en modo append-only (audit.jsonl). Ante desconexiones abruptas o errores de socket, los bloques try/except capturan la excepción sin exponer stack traces ni rutas absolutas en respuestas HTTP hacia el navegador, mitigando la amenaza de Information Disclosure (STRIDE).
3	**Respuesta activa en Firewall (AutoBan default-deny)**	ISO/IEC 27033-4 Cl. 9.2 OWASP ASVS V5.1.1	mitigator.py: L100-185 correlator.py: L138-166	Al superarse los umbrales de escaneo (ej. 5 toques en 60s), se ejecuta block_ip() invocando netsh advfirewall firewall add rule con lista estructurada de argumentos (evitando shell=True). Además, se asocia un temporizador daemon threading.Timer(300, _unblock_ip) para asegurar la expiración controlada de la regla de cuarentena.
4	**Generación de evidencia forense estructurada (.pcap)**	NIST SP 800-218 (SSDF) PW.9.1 ISO 27033-1 Cl. 10.3	mitigator.py: L50-98 dispatcher.py: L41-55	Se investigó la función capture_pcap(). Invoca TShark CLI con filtro BPF host <IP>; si no está instalado, sintetiza una captura libpcap binaria válida (0xA1B2C3D4) con los paquetes TCP SYN de la agresión guardada en src/data/pcap/. Esto garantiza trazabilidad forense analizable en Wireshark sin depender de herramientas de terceros.

3. Investigación de Análisis Estático (SAST) con Bandit

Se ejecutó la herramienta de SAST **Bandit v1.8.3** especializada en seguridad para código Python sobre la totalidad del backend (src/backend/, 1.002 líneas de código analizadas).

Herramienta SAST: Bandit (Python)	**Total de Hallazgos:** 9	**Severidad Alta:** 0 (0%)
Severidad Media: 1 (11.1%)	**Severidad Baja:** 8 (88.9%)	**Líneas de Código:** 1.002 LOC

Interpretación Técnica y Descarte de Falsos Positivos en el SAST:

• **B104 · hardcoded_bind_all_interfaces (honeypot.py:87 · Media):** Bandit detectó enlace a 0.0.0.0. *Resolución:* Es un **falso positivo funcional justificado**, ya que por diseño arquitectónico una trampa Honeypot debe escuchar en todas las interfaces de red para capturar el tráfico de intrusión de atacantes.
• **B603 · subprocess_without_shell_equals_true (mitigator.py:138, 190, 232 · Baja):** Bandit alerta sobre invocación de subprocesos. *Resolución:* Es seguro y cumple OWASP ASVS V5.1.1 porque se invoca estrictamente como **lista estructurada de argumentos** (['netsh', 'advfirewall', ...]), **sin usar shell=True** y con sanitización previa de la IP mediante ipaddress.
• **B105 · hardcoded_password_string (main.py:89 · Baja):** Token de sesión maestro de laboratorio. *Resolución:* En despliegues de producción se delega obligatoriamente a la variable de entorno NETTRAP_SECRET.

Auditoría y Revisión de Secretos en el Repositorio (NIST SSDF PS.1.1):

Se auditó el árbol de archivos y el control de versiones local. Se verificó que el repositorio cuenta con .gitignore impidiendo el versionado de archivos .env, llaves criptográficas y volcados .pcap de evidencia. Las contraseñas administrativas operan mediante variables de entorno (NETTRAP_USER, NETTRAP_PASS_HASH) procesadas con hashing **Argon2id**, cumpliendo con la política de cero secretos en texto plano.

4. Vulnerabilidades según NIST (CVE) que NetTrap-IPS Mitiga

Para responder con rigor al docente, se detalla cómo el motor defensivo previene la explotación de las **5 vulnerabilidades críticas** registradas en el National Vulnerability Database (NVD) del NIST:

Identificador CVE	CVSS / Severidad	Software Afectado	Mecanismo de Mitigación en NetTrap-IPS	Regla Asociada
CVE-2024-37032	**9.8 Crítico**	Ollama LLM Server	Neutraliza el escaneo de puertos de reconocimiento SYN previo antes de que el atacante alcance la API no autenticada en el puerto 11434.	RULE-001 (≥5 toques / 60s)
CVE-2019-0708 (BlueKeep)	**9.8 Crítico**	Microsoft RDP (Port 3389)	La trampa señuelo en 3389 intercepta el primer paquete de conexión anómalo, ejecutando AutoBan en Windows Firewall antes del exploit MS_T120.	RULE-001 Trampa RDP 3389
CVE-2023-38408	**9.8 Crítico**	OpenSSH ssh-agent	Detecta sondeos en puerto SSH señuelo 2222; aplica cuarentena y exporta captura forense .pcap para análisis en Wireshark ante ≥2 intentos.	RULE-003 Trampa SSH 2222
CVE-2015-3306	**10.0 Crítico**	ProFTPd (mod_copy)	Detecta ráfagas de fuerza bruta o sondeo en el puerto 21 señuelo. Aísla la IP agresora antes de la emisión de comandos SITE CPFR / CPTO.	RULE-002 Trampa FTP 21
CVE-2021-44228 (Log4Shell)	**10.0 Crítico**	Apache Log4j2 JNDI	El puerto 8080 trampa recibe los sondeos y cabeceras HTTP de inyección JNDI lookup, registrando la IP y generando alerta sin transmitir al backend.	RULE-004 Trampa HTTP 8080

5. Conclusiones de la Investigación y Próximos Pasos (Clase 4)

Síntesis de Hallazgos: El equipo corroboró que la arquitectura multihilo de NetTrap-IPS opera conforme a los lineamientos de codificación segura de ASVS y SSDF. La combinación de listas blancas con ipaddress, la exclusión de shell=True en subprocesos y el mecanismo de aislamiento en Windows Defender Firewall garantizan una contención en milisegundos con cero hallazgos de severidad alta en SAST.

Correcciones y Metas para la Clase 4:

1. Implementar cifrado simétrico AES-256 en reposo para los registros de auditoría audit.jsonl.
2. Parametrizar dinámicamente el tiempo de cuarentena (300 s) mediante panel web de configuración administrativa.
3. Incorporar validación de certificados mutuos (mTLS) en conexiones remotas de agentes distribuidores.

Fuentes Normativas Consultadas:

• OWASP Application Security Verification Standard (ASVS) v5.0 (Secciones V5, V6, V7, V9).
• NIST SP 800-218: Secure Software Development Framework (SSDF) v1.1 (Prácticas PW.7, PW.9, PS.1).
• ISO/IEC 27033-1 / 27033-4: Network Security Guidelines and Security Gateways.
• National Vulnerability Database (NVD - NIST): Entradas CVE-2024-37032, CVE-2019-0708, CVE-2023-38408, CVE-2015-3306, CVE-2021-44228.

Declaración de Cierre y Veracidad:

El equipo declara que los controles e investigaciones aquí documentados reflejan fielmente el estado del repositorio de código, los análisis SAST ejecutados y las pruebas funcionales del cortafuegos.

Said Alexander Pacheco Moncada
Líder Técnico · C.C. 1092528951

Margit Dayanna Barrera G.
Desarrolladora · C.C. 1014189353

Michel Daniela Bayona Diaz
Seguridad · C.C. 1096802414